

Informe Profesional de Pentesting

Actividad A08 — Hacking Ético

Cliente: INSECUR S.A. — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información

Licenciatura en Sistemas de Información — Facultad de Informática y Diseño

Docente: Ing. Rodrigo Atilio Elgueta

Contratista: Facundo Calderón — Username THM: facucalderon482

Ciclo Académico Vigente

Contenido

1. Contexto de la Contratación	3
Carta de Autorización — INSECUR S.A.	3
Ética y Legalidad.....	3
2. Modelo de Trabajo: Núcleo + Sala de Elección	3
2.1. Nivel 1 — Núcleo obligatorio.....	3
2.2. Nivel 2 — Sala de elección	3
3. PARTE II: INFORME DE PENTESTING	4
3.1. Datos generales.....	4
3.2. Pre-pentesting	4
Alcance del trabajo.....	4
Reglas de Enfrentamiento (ROE)	4
Autorización	4
Metodología utilizada	5
3.3. Durante: Hallazgos por fase.....	5
Hallazgo BP-01	5
Hallazgo BP-02	6
Hallazgo BP-03	6
Hallazgo BP-04	7
Hallazgo BP-05	8
Hallazgo VV-01	8
Hallazgo VV-02	9
Hallazgo VV-03	10
3.4. Resumen ejecutivo de hallazgos	10
3.5. Post-pentesting: Recomendaciones.....	10
Recomendaciones técnicas (parches y configuraciones)	11
Recomendaciones administrativas (políticas y procesos)	11
4. PARTE III: PROTOCOLO DE CONTINGENCIA.....	11
Escenario de falla	11
Impacto sobre la continuidad del negocio.....	11
Plan de respuesta.....	11
RTO y RPO estimados	12
5. Anexos.....	12
Anexo A — Bitácora de comandos.....	12
Anexo B — Capturas de pantalla.....	12
Anexo C — Hashes de las flags/credenciales obtenidas.....	12
Anexo D — Declaración ética firmada.....	13
6. Fuentes y bibliografía.....	13

1. Contexto de la Contratación

Carta de Autorización — INSECUR S.A.

Cliente: INSECUR S.A.

Contratista: Facundo Calderón — Estudiante de Seguridad Aplicada a Sistemas de Información (FID-UCH).

Objeto del contrato: La compañía INSECUR S.A., preocupada por los niveles de seguridad de sus sistemas, contrata sus servicios profesionales de Hacking Ético para elaborar un plan de seguridad y contingencia.

Alcance autorizado: Únicamente los entornos de laboratorio de la plataforma TryHackMe asignados en esta guía. Cualquier acción fuera de este alcance queda estrictamente prohibida y constituye un delito conforme la legislación vigente.

Entregable: Informe profesional de pentesting, incluyendo documentación previa, durante y posterior a la intervención, más un protocolo de contingencia para garantizar la continuidad de negocio.

Modalidad: Individual.

Repositorio de entrega: https://github.com/UCHSeguridad2026/TP_THM.git (branch calderon-facundo).

Ética y Legalidad

Esta actividad se desarrolla en entornos controlados (sandbox). Queda absolutamente prohibido aplicar las técnicas aprendidas contra sistemas reales sin autorización escrita. El incumplimiento será considerado falta ética grave y podrá derivar en sanciones académicas y legales.

2. Modelo de Trabajo: Núcleo + Sala de Elección

2.1. Nivel 1 — Núcleo obligatorio

- Pentesting Fundamentals — metodología y fases del pentesting profesional.
- Basic Pentesting — aplicación práctica completa: enumeración, explotación y escalada de privilegios.

2.2. Nivel 2 — Sala de elección

Sala elegida: Vulniversity (<https://tryhackme.com/room/vulniversity>). Enfoque web + explotación de carga de archivos y escalada de privilegios por binario SUID. Justificación en la Sección 3.2.

3. PARTE II: INFORME DE PENTESTING

3.1. Datos generales

Cliente	INSECUR S.A.
Contratista (alumno/a)	Facundo Calderón
DNI	46.162.078
Username TryHackMe	facucalderon482
Email institucional	calderonfacundo@uch.edu.ar
Sala de elección (Nivel 2)	Vulniversity
Branch en GitHub	calderon-facundo
Fecha de inicio	02/10/2026
Fecha de cierre	07/10/2026

3.2. Pre-pentesting

Alcance del trabajo

Dentro del alcance: exclusivamente las máquinas virtuales asignadas en la plataforma TryHackMe, accedidas a través de la VPN oficial de THM:

- Basic Pentesting (núcleo obligatorio) — máquina Linux con servicios SSH, HTTP, Samba y Tomcat. IPs asignadas durante la sesión: 10.67.154.221 y 10.65.134.114 (reasignada al expirar el tiempo de laboratorio).
- Vulniversity (sala de elección) — máquina Linux con servicios FTP, SSH, Samba, proxy Squid y servidor web Apache en puerto no estándar. IPs asignadas: 10.67.178.72 y 10.65.184.174 (reasignada al expirar el tiempo de laboratorio).

Fuera del alcance: toda infraestructura real de INSECUR S.A., cualquier sistema de terceros, la propia plataforma TryHackMe y la infraestructura de red de la facultad. No se realizaron ataques de denegación de servicio ni pruebas destructivas.

Reglas de Enfrentamiento (ROE)

- Las pruebas se ejecutaron únicamente contra las IPs asignadas dinámicamente por TryHackMe, y solo mientras las máquinas estuvieron desplegadas por el estudiante.
- Se trabajó sobre entornos de laboratorio aislados; no se accedió a datos reales ni personales.
- La fuerza bruta (Hydra) se limitó a 4 hilos para no degradar el servicio, y se detuvo al hallar la primera credencial válida.
- No se instaló persistencia ni puertas traseras; el único artefacto cargado (web shell en Vulniversity) se utilizó para obtener acceso y no se dejó operativo tras la prueba.
- Las credenciales y claves obtenidas se trataron como material sensible: no se incluyen en texto plano en el repositorio; solo se documenta la evidencia de su compromiso (ver Anexo C, hashes).

Autorización

Declaro contar con autorización expresa de la cátedra de Seguridad Aplicada a Sistemas de Información (FID-UCH) para realizar las pruebas de intrusión sobre los entornos de laboratorio de TryHackMe indicados en el alcance. Todas las actividades se desarrollaron con fines exclusivamente académicos, dentro de dichos entornos controlados.

Metodología utilizada

Se adoptó una metodología basada en PTES (Penetration Testing Execution Standard), complementada con la NIST SP 800-115 y, para la parte web, la OWASP Web Security Testing Guide (WSTG).

Justificación: PTES ofrece un marco de fases claro (pre-engagement, reconocimiento, escaneo, explotación, post-explotación y reporte) que se alinea con el flujo pedagógico de la actividad. NIST SP 800-115 aporta rigor técnico y trazabilidad de la evidencia, mientras que OWASP WSTG resulta pertinente para la vulnerabilidad de carga de archivos encontrada en Vulniversity.

3.3. Durante: Hallazgos por fase

Se emplea el prefijo BP para Basic Pentesting y VV para Vulniversity.

Hallazgo BP-01

ID del hallazgo	BP-01
Máquina	Basic Pentesting
Fase	Escaneo ☒ / Explotación ☒
Descripción	El usuario del sistema jan posee una contraseña débil (armando) obtenida mediante fuerza bruta sobre el servicio SSH con una wordlist corta (best1050.txt), tras identificar el nombre de usuario vía enumeración SMB. La sala indica que, al haber enumerado otro usuario del sistema, el camino esperado es precisamente un ataque de fuerza bruta dirigido a sus credenciales.
Componente afectado	Servicio SSH (puerto 22) / cuenta de usuario jan.
Categoría (OWASP/CWE)	CWE-521 (Weak Password Requirements), CWE-307 (Improper Restriction of Excessive Authentication Attempts)
CVE (si aplica)	No aplica (mala configuración / política de credenciales)
CVSS estimado	Alto
Evidencia	bitacora/bp_hydra.png (Hydra devuelve login: jan / password: armando)
Herramienta utilizada	nmap, enum4linux, hydra
Impacto en la Tríada CIA	Confidencialidad, Integridad
Salvaguarda propuesta	Imponer política de contraseñas robustas, deshabilitar autenticación por contraseña en SSH (usar claves) y aplicar fail2ban para bloquear intentos de fuerza bruta.
Riesgo residual tras aplicar	Bajo

Hallazgo BP-02

ID del hallazgo	BP-02
Máquina	Basic Pentesting
Fase	Enumeración
Descripción	El servicio Samba (puertos 139/445) permitía enumeración anónima (sesión nula) vía RID cycling, exponiendo los nombres de usuario del sistema (jan, kay, ubuntu), información clave para el ataque de fuerza bruta posterior.
Componente afectado	Servicio Samba/SMB.
Categoría (OWASP/CWE)	CWE-200 (Exposure of Sensitive Information to an Unauthorized Actor)
CVE (si aplica)	No aplica (configuración)
CVSS estimado	Medio
Evidencia	bitacora/enum4linux.txt
Herramienta utilizada	enum4linux
Impacto en la Tríada CIA	Confidencialidad
Salvaguarda propuesta	Deshabilitar sesiones nulas en Samba (restrict anonymous), limitar el acceso a los recursos compartidos y exponer SMB solo a redes internas confiables.
Riesgo residual tras aplicar	Bajo

Hallazgo BP-03

ID del hallazgo	BP-03
Máquina	Basic Pentesting
Fase	Enumeración
Descripción	Mediante enumeración web (gobuster) se accedió al directorio /development/, encontrando dos archivos de texto expuestos (dev.txt y j.txt) que revelaron las iniciales de usuarios del sistema (J, K), la presencia de Apache Struts 2.5.12 en el servidor y la confirmación de que el usuario J tenía una contraseña débil.
Componente afectado	Servidor web Apache (puerto 80).
Categoría (OWASP/CWE)	CWE-200 (Exposure of Sensitive Information to an Unauthorized Actor)
CVE (si aplica)	No aplica
CVSS estimado	Medio

Evidencia	bitacora/gobuster_80.txt, bitacora/dev.txt, bitacora/j.txt
Herramienta utilizada	gobuster, curl
Impacto en la Tríada CIA	Confidencialidad
Salvaguarda propuesta	Deshabilitar el listado de directorios (Options -Indexes), eliminar archivos de notas/desarrollo en entornos productivos.
Riesgo residual tras aplicar	Bajo

Hallazgo BP-04

ID del hallazgo	BP-04
Máquina	Basic Pentesting
Fase	Post-explotación
Descripción	La clave privada SSH del usuario kay (/home/kay/.ssh/id_rsa) era legible por el usuario jan, y su passphrase de cifrado era débil (beeswax), recuperable con John the Ripper tras extraer el hash con ssh2john. Esto permitió el movimiento lateral de jan a kay autenticándose directamente por SSH con la clave.
Componente afectado	Permisos de la clave privada SSH de kay.
Categoría (OWASP/CWE)	CWE-522 (Insufficiently Protected Credentials), CWE-732 (Incorrect Permission Assignment)
CVE (si aplica)	No aplica
CVSS estimado	Alto
Evidencia	bitacora/bp_ssh_key.png (permisos -rw-r--r-- en /home/kay/.ssh/id_rsa, legible por otros usuarios), bitacora/bp_pass_bak.png (login exitoso como kay vía ssh -i con la clave y la passphrase crackeada)
Herramienta utilizada	linpeas.sh, ssh2john, John the Ripper, ssh
Impacto en la Tríada CIA	Confidencialidad, Integridad
Salvaguarda propuesta	Restringir permisos de claves privadas a 600 y al propietario; usar passphrases robustas; no almacenar claves privadas accesibles por otros usuarios.
Riesgo residual tras aplicar	Bajo

Hallazgo BP-05

ID del hallazgo	BP-05
Máquina	Basic Pentesting
Fase	Post-explotación
Descripción	En el directorio personal de kay existía el archivo pass.bak con una contraseña en texto plano (heresareallystrongpasswordthatfollowsthepasswordpolicy\$\$), que permitió escalar privilegios a root mediante sudo.
Componente afectado	Almacenamiento de credenciales en texto plano (/home/kay/pass.bak).
Categoría (OWASP/CWE)	CWE-312 (Cleartext Storage of Sensitive Information), CWE-256 (Unprotected Storage of Credentials)
CVE (si aplica)	No aplica
CVSS estimado	Alto
Evidencia	bitacora/bp_pass_bak.png (cat /home/kay/pass.bak muestra la contraseña en texto plano). Hash SHA-256 de la contraseña en Anexo C.
Herramienta utilizada	Shell interactiva, cat, sudo
Impacto en la Tríada CIA	Confidencialidad, Integridad, Disponibilidad
Salvaguarda propuesta	Nunca almacenar credenciales en texto plano; usar un gestor de secretos; aplicar el principio de mínimo privilegio en sudoers.
Riesgo residual tras aplicar	Bajo

Hallazgo VV-01

ID del hallazgo	VV-01
Máquina	Vulniversity
Fase	Escaneo ☒ / Explotación ☒
Descripción	El formulario de carga de archivos del servidor web (puerto 3333, directorio /internal/) validaba la extensión de forma deficiente: bloqueaba .php pero permitía .phtml. Esto posibilitó subir y ejecutar un reverse shell PHP (ejecución remota de código), obteniendo una shell como www-data.
Componente afectado	Funcionalidad de subida de archivos (Apache en puerto 3333).
Categoría (OWASP/CWE)	OWASP A03:2021 (Injection) / A05 (Security Misconfiguration); CWE-434 (Unrestricted Upload of File with Dangerous Type)
CVE (si aplica)	No aplica (vulnerabilidad de lógica/validación)
CVSS estimado	Crítico

Evidencia	bitacora/vulniversity_gobuster.txt, vv_shell.png (conexión entrante y whoami → www-data)
Herramienta utilizada	gobuster, php reverse shell, netcat
Impacto en la Tríada CIA	Confidencialidad, Integridad, Disponibilidad
Salvaguarda propuesta	Validar el tipo real del archivo (contenido/MIME, no solo la extensión) con lista blanca estricta; almacenar los archivos subidos fuera del webroot y sin permisos de ejecución; renombrar los archivos del lado del servidor.
Riesgo residual tras aplicar	Bajo

Hallazgo VV-02

ID del hallazgo	VV-02
Máquina	Vulniversity
Fase	Post-explotación
Descripción	El binario /bin/systemctl tenía el bit SUID activado indebidamente. Desde el usuario www-data se abusó de esta mala configuración creando un servicio malicioso ejecutado como root, logrando la escalada total de privilegios y la lectura de la flag de root.
Componente afectado	Permisos del binario /bin/systemctl (bit SUID).
Categoría (OWASP/CWE)	CWE-250 (Execution with Unnecessary Privileges), CWE-732 (Incorrect Permission Assignment)
CVE (si aplica)	No aplica (mala configuración de permisos)
CVSS estimado	Crítico
Evidencia	Captura find SUID (usuario bill / user.txt) y captura de shell root + /root/root.txt. Hashes de ambas flags en Anexo C.
Herramienta utilizada	find (búsqueda SUID), systemctl, netcat
Impacto en la Tríada CIA	Confidencialidad, Integridad, Disponibilidad
Salvaguarda propuesta	Quitar el bit SUID (chmod u-s /bin/systemctl); auditar periódicamente los binarios SUID; aplicar el principio de mínimo privilegio.
Riesgo residual tras aplicar	Bajo

Hallazgo VV-03

ID del hallazgo	VV-03
Máquina	Vulniversity
Fase	Escaneo
Descripción	Superficie de ataque amplia: la máquina expone múltiples servicios (FTP vsftpd 3.0.5, SSH, Samba, proxy Squid 4.10 y Apache en un puerto no estándar, 3333), varios revelando banners con número de versión que facilitan la identificación de vulnerabilidades.
Componente afectado	Configuración de servicios y exposición de versiones.
Categoría (OWASP/CWE)	OWASP A05:2021 (Security Misconfiguration); CWE-200
CVE (si aplica)	No aplica directamente
CVSS estimado	Bajo
Evidencia	bitacora/vulniversity_nmap_sV.txt, bitacora/vulniversity_nmap_todos.txt
Herramienta utilizada	nmap
Impacto en la Tríada CIA	Confidencialidad
Salvaguarda propuesta	Reducir la superficie de ataque (cerrar/deshabilitar servicios innecesarios), ocultar los banners de versión y mantener los servicios actualizados.
Riesgo residual tras aplicar	Bajo

3.4. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	2	VV-01, VV-02
Alto	3	BP-01, BP-04, BP-05
Medio	2	BP-02, BP-03
Bajo	1	VV-03
Total	8	

Conclusión ejecutiva: ambas máquinas fueron comprometidas hasta obtener privilegios de root. Las causas raíz predominantes son credenciales débiles o mal protegidas (contraseñas y claves SSH) y malas configuraciones (validación de carga de archivos y permisos SUID). Ninguna vulnerabilidad requirió exploits de día cero: todas derivan de prácticas de hardening ausentes, lo que indica que un plan de remediación de bajo costo reduciría drásticamente el riesgo.

3.5. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

- (Crítico) Corregir la validación de carga de archivos: lista blanca por contenido/MIME, almacenamiento fuera del webroot y sin ejecución, y renombrado del lado del servidor (VV-01).
- (Crítico) Quitar el bit SUID de /bin/systemctl y auditar todos los binarios SUID del sistema (VV-02).
- (Alto) Restringir los permisos de las claves privadas SSH a 600 y proteger sus passphrases (BP-04).
- (Alto) Eliminar toda credencial almacenada en texto plano y adoptar un gestor de secretos (BP-05).
- (Alto) Imponer políticas de contraseñas robustas, desactivar la autenticación por contraseña en SSH a favor de claves e implementar fail2ban (BP-01).
- (Medio) Deshabilitar sesiones nulas en Samba (BP-02) y restringir el listado de directorios y archivos de desarrollo en el servidor web (BP-03).
- (Bajo) Reducir servicios expuestos y ocultar banners de versión (VV-03).

Recomendaciones administrativas (políticas y procesos)

- Establecer una política de contraseñas corporativa (longitud, complejidad, rotación) y de gestión de credenciales/secretos.
- Implementar un proceso de hardening y una línea base de configuración segura para todos los servidores, con revisiones periódicas.
- Realizar auditorías de seguridad y pentests de forma regular.
- Capacitar al personal técnico en desarrollo seguro (validación de entradas, manejo de archivos) y en el principio de mínimo privilegio.
- Mantener un inventario de activos y servicios expuestos y un ciclo de gestión de parches.

4. PARTE III: PROTOCOLO DE CONTINGENCIA

Escenario de falla

Durante la fase de explotación se cargó y ejecutó un reverse shell en el servidor web de Vulniversity (VV-01), y se realizaron ataques de fuerza bruta contra el servicio SSH de Basic Pentesting (BP-01). En un entorno de producción, la subida y ejecución de archivos arbitrarios, la manipulación de servicios con systemctl (VV-02) o un escaneo/fuerza bruta intensivo podrían provocar la caída o indisponibilidad del servicio, corrupción de datos, o la ejecución de un servicio malicioso que afecte la estabilidad del host.

Impacto sobre la continuidad del negocio

Se vería afectado principalmente el servicio web público de INSECUR S.A. (portal/aplicación) y la administración remota por SSH, con posible indisponibilidad total durante el incidente. Un compromiso de root implica además riesgo de fuga de datos confidenciales y pérdida de integridad de la información. El tiempo de afectación estimado es de 1 a 4 horas hasta la restauración, si se cuenta con backups y procedimientos definidos.

Plan de respuesta

- Activación: detección mediante monitoreo (IDS/IPS, alertas de integridad de archivos en el webroot, picos de CPU/red, logs de autenticación fallida y de subida anómala).
- Contención (primeros 15 minutos): aislar el servidor afectado de la red, suspender el servicio de carga de archivos, bloquear la IP origen y preservar evidencia (logs, memoria).

- Recuperación: restaurar el servicio desde un backup limpio o un servidor espejo, aplicar los parches/configuraciones correctivas (validación de uploads, remoción de SUID, políticas de contraseñas), rotar credenciales y claves comprometidas.
- Comunicación: notificar a la dirección de TI, al responsable de seguridad y, según corresponda, a clientes y autoridades regulatorias.
- Post-mortem: documentar el incidente, la causa raíz y las lecciones aprendidas; actualizar la línea base de hardening y los controles de detección.

RTO y RPO estimados

RTO (Recovery Time Objective): 4 horas.

RPO (Recovery Point Objective): 24 horas (último respaldo diario).

5. Anexos

Anexo A — Bitácora de comandos

Basic Pentesting: bitacora/nmap_inicial.txt, bitacora/gobuster_80.txt, bitacora/dev.txt, bitacora/j.txt, bitacora/enum4linux.txt, bitacora/linpeas_output.txt, bitacora/bp_hydra.png (captura del comando Hydra, no exportado con -o).

Vulnversity: bitacora/vulnversity_nmap_sV.txt, bitacora/vulnversity_nmap_todos.txt, bitacora/vulnversity_gobuster.txt, bitacora/vv_shell.png.

Los comandos fueron depurados de credenciales/secretos antes de su publicación.

Anexo B — Capturas de pantalla

Se recomienda organizar las capturas ya tomadas en la siguiente estructura dentro de evidencias/:

- evidencias/basic-pentesting/explotacion/explotacion_hydra.png (bp_hydra.png)
- evidencias/basic-pentesting/post/post_kay_sshkey.png (bp_ssh_key.png)
- evidencias/basic-pentesting/post/post_pass_bak.png (bp_pass_bak.png)
- evidencias/vulnversity/explotacion/explotacion_shell_wwwdata.png (vv_shell.png)
- evidencias/vulnversity/post/post_suid_find.png (listado find -perm -4000)
- evidencias/vulnversity/post/post_flag_root.png (shell root + /root/root.txt)

Anexo C — Hashes de las flags/credenciales obtenidas

Formato: sha256(valor) — se documenta el hash en lugar del valor en texto plano, conforme a la guía de la cátedra.

- BP — contraseña final (pass.bak → root):
3ffd53ec80858f9ddcd75d69102724ab1bc1020855fff924227f618c4bfccf57
- VV — user flag (usuario bill):
d324bd433001e5bdfe39e04d794539c15b51982a5bf6fc78efea46369b7bf956
- VV — root flag (/root/root.txt):
cfbc740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8

Nota: no se registró una flag de root independiente para Basic Pentesting; la sala utiliza como entregable la contraseña final obtenida, hasheada arriba.

Anexo D — Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Facundo Calderón

07/10/2026

Firma — Facundo Calderón

Fecha

6. Fuentes y bibliografía

- TryHackMe. Pentesting Fundamentals: sala oficial.
- TryHackMe. Basic Pentesting: sala oficial.
- TryHackMe. Vulniversity: sala oficial.
- OWASP Foundation. Web Security Testing Guide (WSTG): sitio oficial.
- PTES. Penetration Testing Execution Standard: sitio oficial.
- NIST (2008). Technical Guide to Information Security Testing and Assessment (SP 800-115).
- Chicano Tejada, E. (2023). Auditoría de seguridad informática. IFCT0109 (2.^a ed.). IC Editorial — eLibro.
- White, A. & Clark, B. (2017). BTFM: Blue Team Field Manual. CreateSpace Independent Publishing Platform.